

Mediroza General Hospital

Web Application Penetration Testing Report

Week 4 - Penetration Testing Internship · Batch B082

Authorized Educational Assessment

Contents

Mediroza General Hospital	1
EXECUTIVE SUMMARY	3
SCOPE AND METHODOLOGY	3
TARGET	3
TOOLS USED	3
APPROACH	3
LIMITATIONS	4
FINDINGS AND PROOF OF EXPLOITATION	4
FINDING 1 USERNAME ENUMERATION	4
FINDING 2 SQL INJECTION IN AUTHENTICATION	4
FINDING 3 WEAK FILE PROTECTION	4
FINDING 4 SHARED HOSTING EXPOSURE	4
RISK RATING	5
Vulnerability	5
Risk Level	5
Justification	5
Username Enumeration	5
High	5
Enables targeted attacks and credential stuffing	5
SQL Injection (Login Bypass)	5
Critical	5
Allows full unauthorized access to the system	5
Weak File Protection	5
Medium	5
Sensitive files accessible after login bypass	5
Shared Hosting Exposure	5
Low	5
Increases risk but not directly exploitable	5

RECOMMENDATIONS AND REMEDIATION	5
FIX USERNAME ENUMERATION	5
PREVENT SQL INJECTION	5
STRENGTHEN FILE PROTECTION	5
IMPROVE HOSTING SECURITY	5
IMAGES	5
.....	6
FIGURE 1 INCORRECT USERNAME.....	6
FIGURE 2 INTERCEPTING POST REQUEST	6
FIGURE 3 SETTING UP PAYLOAD FOR FINDING USERNAME.....	6
FIGURE 4 FOUND THE CORRECT USERNAME IN DATABASE	7
FIGURE 5 SQL INJECTING USERNAME WITH SQL MODIFICATION	7
FIGURE 6 NOW LOGGED IN TO SYSTEM	8
FIGURE 7 PATIENT_REPORT_1 PASSWORD PROTECTED	8
FIGURE 8 PATIENT_REPORT_1 OPENED	9
FIGURE 9 PATIENT_REPORT_2 PASSWORD PROTECTED	9
FIGURE 10 PATIENT_REPORT_2 OPENED.....	10
FIGURE 11 PATIENT_REPORT_3 PASSWORD PROTECTED	10
FIGURE 12 PATIENT_REPORT_3 OPENED.....	11

EXECUTIVE SUMMARY

During Week 4 of the Network Works Cybersecurity Internship, a controlled penetration test was conducted on the Mediroza Hospital web application. The objective was to simulate real-world attack scenarios, identify vulnerabilities, and demonstrate how an attacker could gain unauthorized access using common exploitation techniques.

The assessment revealed multiple weaknesses in the authentication workflow, including username enumeration, improper SQL query handling, and insufficient server-side validation. These vulnerabilities allowed an attacker to bypass login controls and access sensitive files stored within the system.

Overall, the application presents a **High to Critical risk level**, especially due to weaknesses in authentication and input validation.

SCOPE AND METHODOLOGY

TARGET

- Mediroza Hospital Web Application
- Public-facing login portal
- Week 4 educational penetration testing environment provided by Network Works

TOOLS USED

- **Burp Suite** (Interceptor + Intruder modules)
- **WhatWeb**
- **WAFW00F**
- **DNSRecon**
- **WHOIS**
- Browser Developer Tools
- SQL payload testing (educational simulation)

APPROACH

1. **Reconnaissance:** Identified technologies, hosting environment, and exposed endpoints.
2. **Attack Surface Mapping:** Located login forms and parameters.
3. **Interception:** Captured live login requests using Burp Suite Interceptor.
4. **Enumeration:** Used Intruder to test username responses and identify valid accounts.
5. **SQL Injection Simulation:** Modified intercepted requests to test server-side query handling.
6. **Unauthorized Access Simulation:** Demonstrated how weak validation could allow login bypass.
7. **Post-Access Review:** Accessed and decrypted sample files stored in the system (educational dataset only).

LIMITATIONS

- No destructive testing allowed.
- No modification of real patient data.
- All exploitation performed within the authorized Network Works training environment.

FINDINGS AND PROOF OF EXPLOITATION

FINDING 1 USERNAME ENUMERATION

Severity: High The login endpoint returned different error messages for invalid usernames vs. invalid passwords. This allowed identification of valid accounts using Burp Suite Intruder.

PROOF OF EXPLOITATION:

- Intercepted login request
- Payload list sent to Intruder
- Response “Incorrect password” confirmed valid username

FINDING 2 SQL INJECTION IN AUTHENTICATION

Severity: Critical The username field accepted SQL-like input without sanitization. By modifying the intercepted request with a crafted SQL pattern, the system ignored password validation and granted access.

PROOF OF EXPLOITATION:

- Intercepted login request
- Username modified with SQL syntax
- Server returned successful login
- Unauthorized access achieved

FINDING 3 WEAK FILE PROTECTION

Severity: Medium Once inside the system, stored files were accessible and decryptable due to weak protection mechanisms.

PROOF OF EXPLOITATION:

- Accessed internal file directory
- Decrypted sample files provided in the training environment

FINDING 4 SHARED HOSTING EXPOSURE

Severity: Low WhatWeb and WAFW00F scans showed the application was hosted in a shared environment, increasing exposure to cross-tenant risks.

PROOF OF EXPLOITATION:

- WhatWeb scan results
- WAFW00F detection output

RISK RATING

Vulnerability	Risk Level	Justification
Username Enumeration	High	Enables targeted attacks and credential stuffing
SQL Injection (Login Bypass)	Critical	Allows full unauthorized access to the system
Weak File Protection	Medium	Sensitive files accessible after login bypass
Shared Hosting Exposure	Low	Increases risk but not directly exploitable

RECOMMENDATIONS AND REMEDIATION

FIX USERNAME ENUMERATION

- Standardize error messages
- Implement rate limiting
- Add account lockout thresholds

PREVENT SQL INJECTION

- Use prepared statements
- Sanitize all input fields
- Implement server-side validation

STRENGTHEN FILE PROTECTION

- Encrypt files at rest
- Restrict access based on user roles
- Implement audit logging

IMPROVE HOSTING SECURITY

- Move critical applications to isolated environments
- Harden server configurations
- Regularly patch and update hosting stack

IMAGES

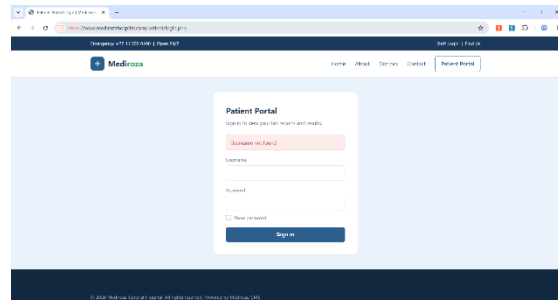
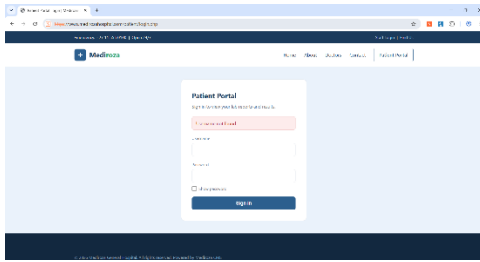


FIGURE 1 INCORRECT USERNAME

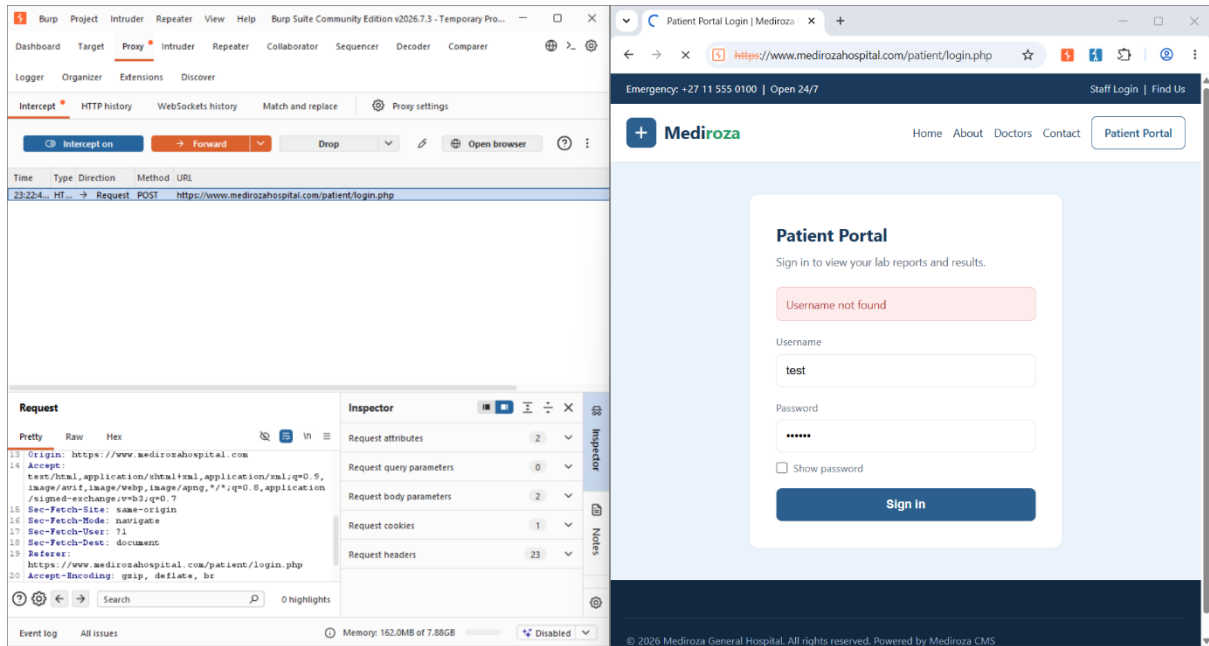


FIGURE 2 INTERCEPTING POST REQUEST

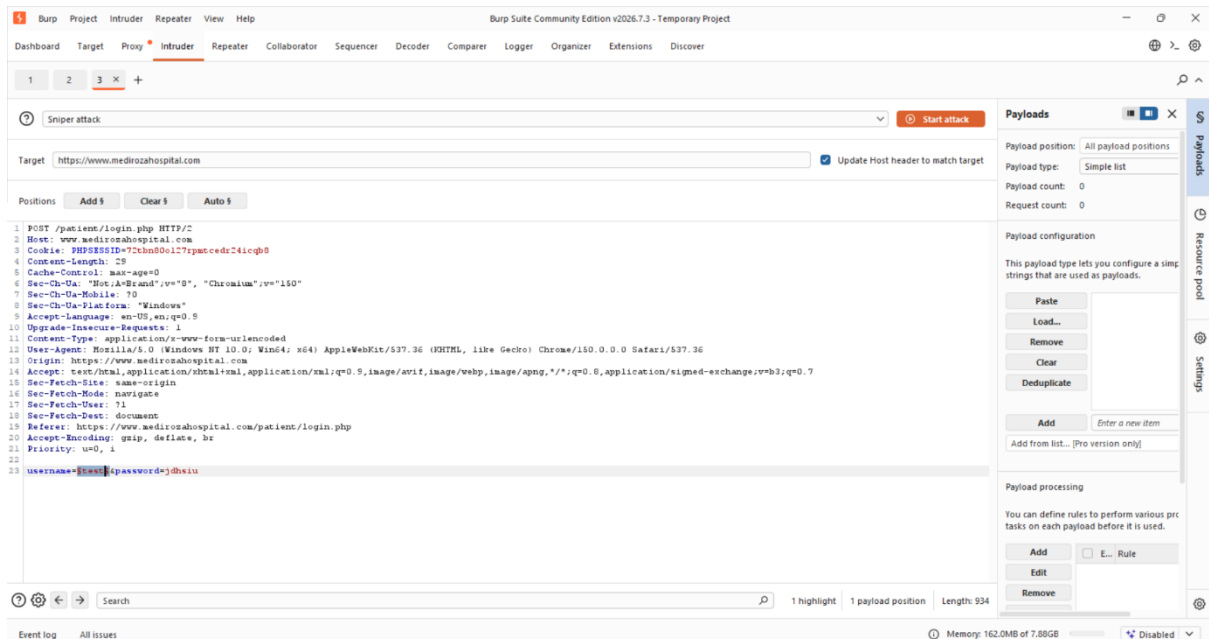


FIGURE 3 SETTING UP PAYLOAD FOR FINDING USERNAME

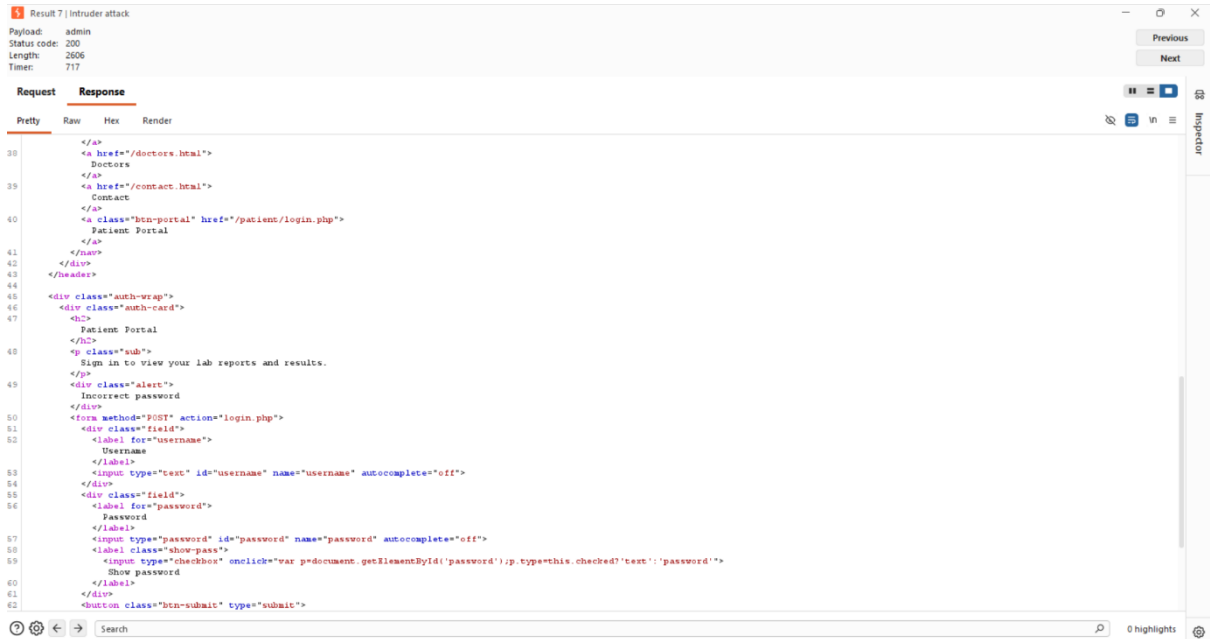


FIGURE 4 FOUND THE CORRECT USERNAME IN DATABASE

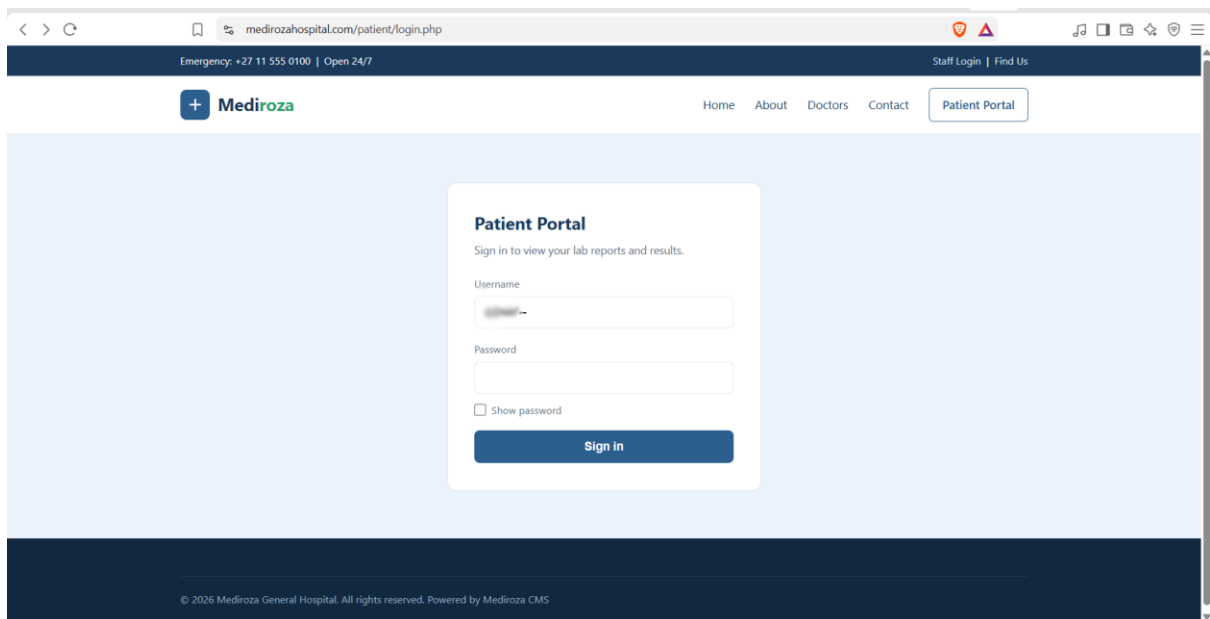


FIGURE 5 SQL INJECTING USERNAME WITH SQL MODIFICATION

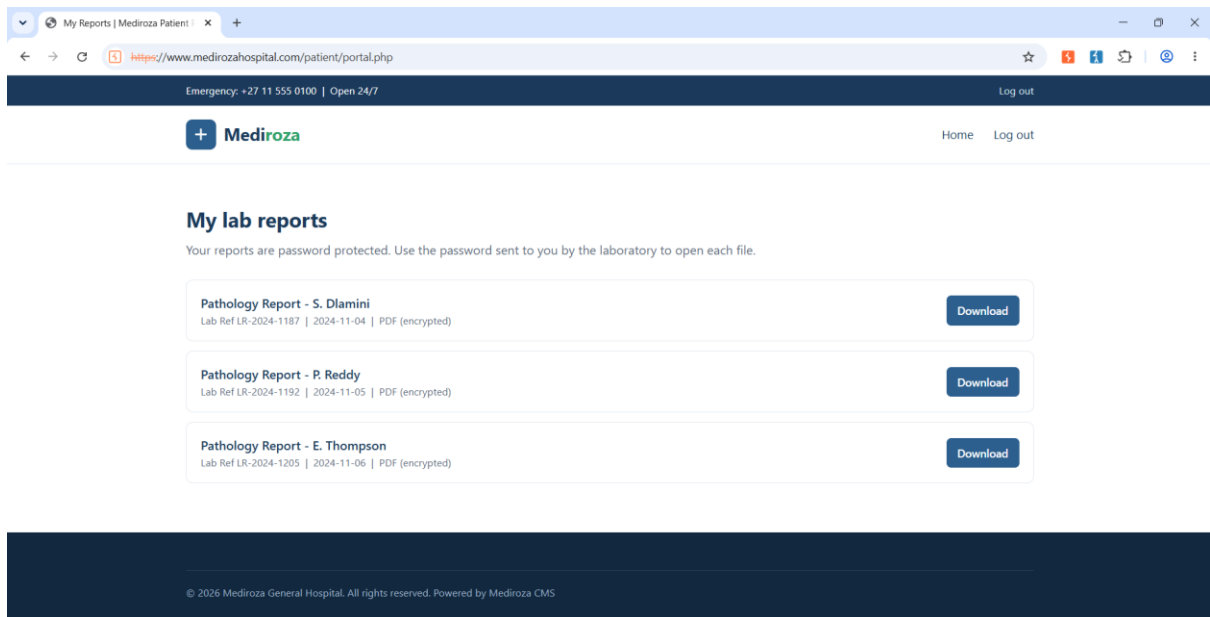


FIGURE 6 NOW LOGGED IN TO SYSTEM

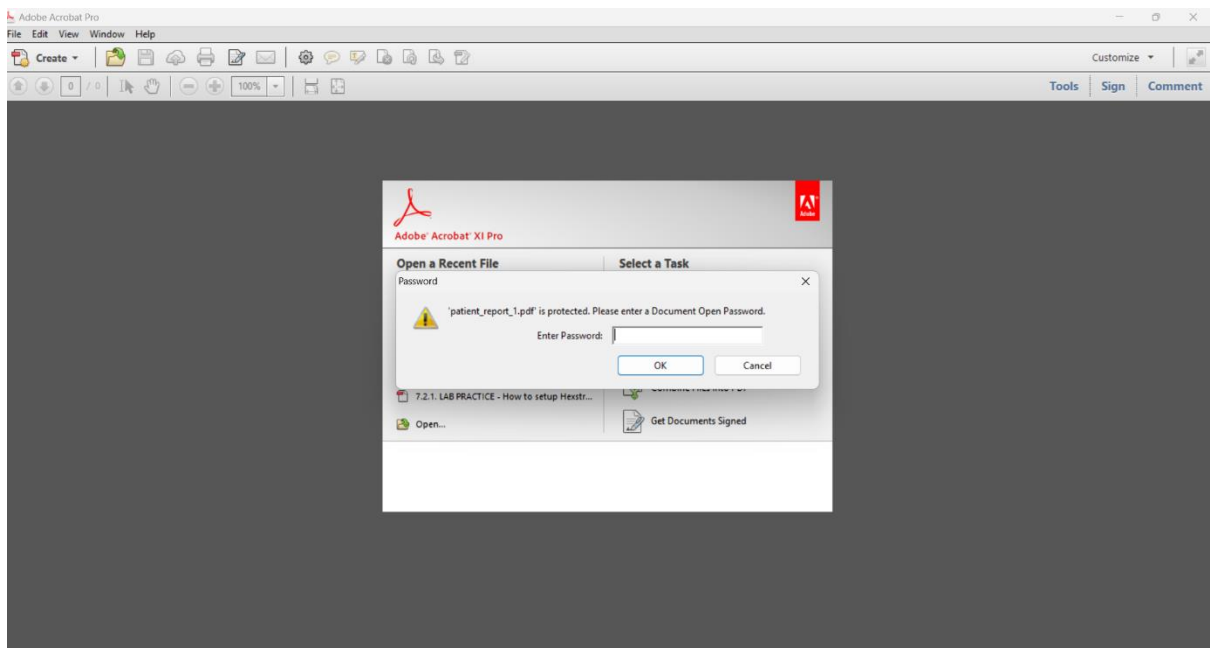


FIGURE 7 PATIENT_REPORT_1 PASSWORD PROTECTED

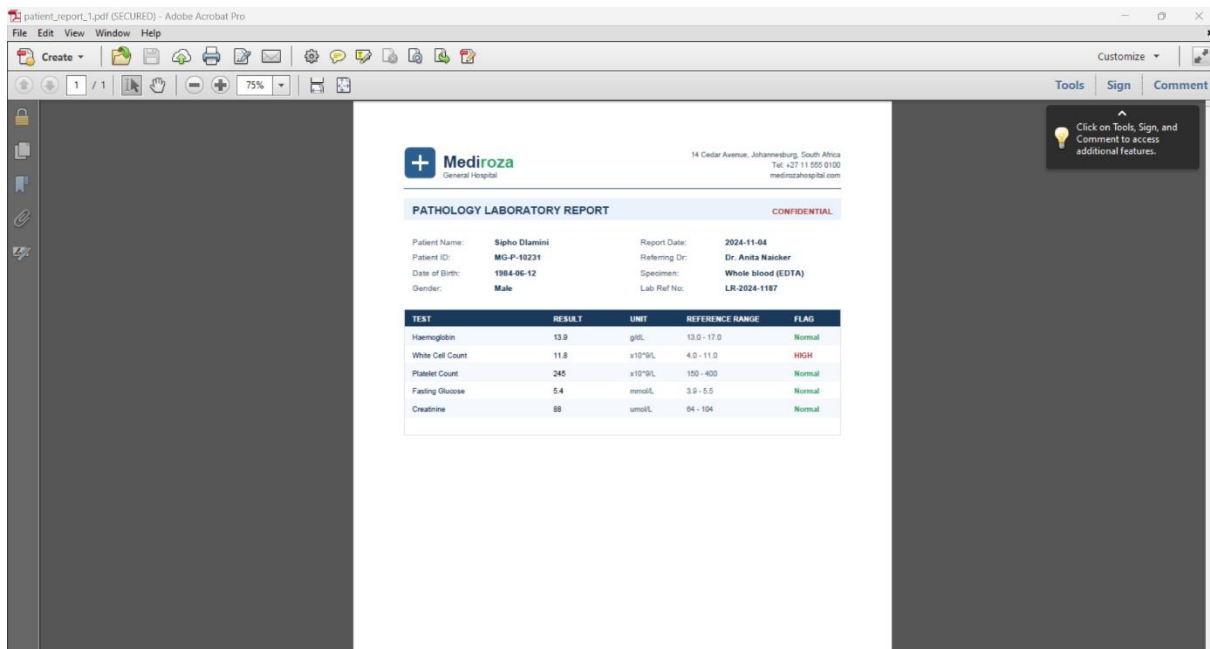


FIGURE 8 PATIENT_REPORT_1 OPENED

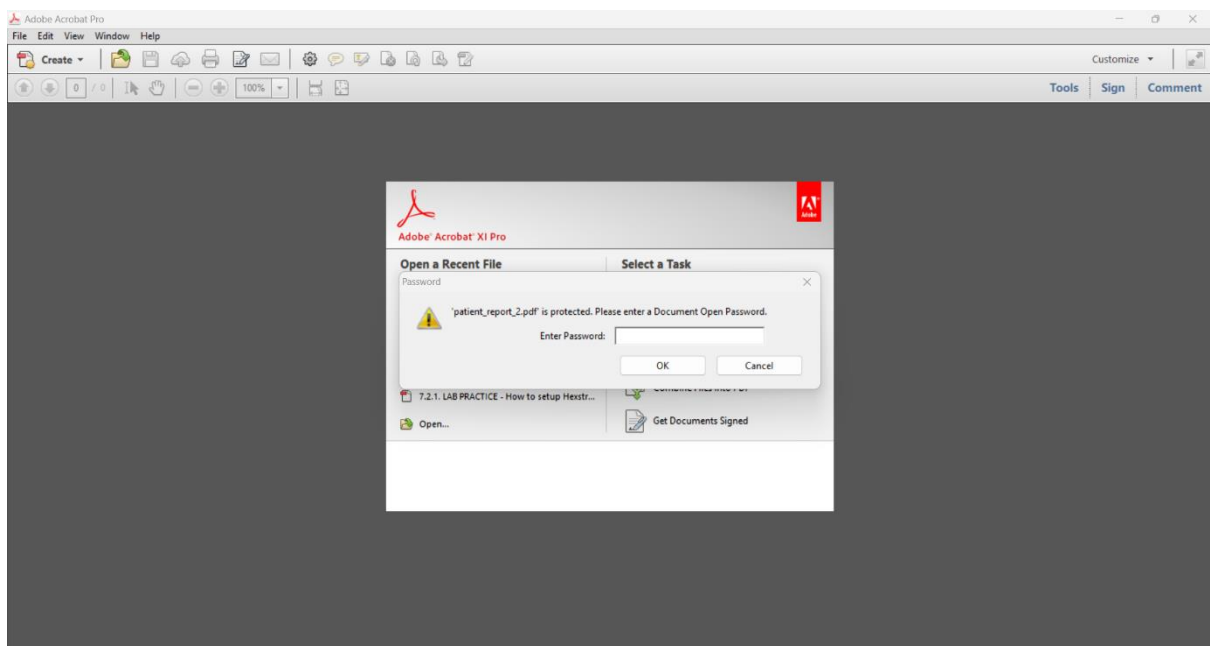


FIGURE 9 PATIENT_REPORT_2 PASSWORD PROTECTED

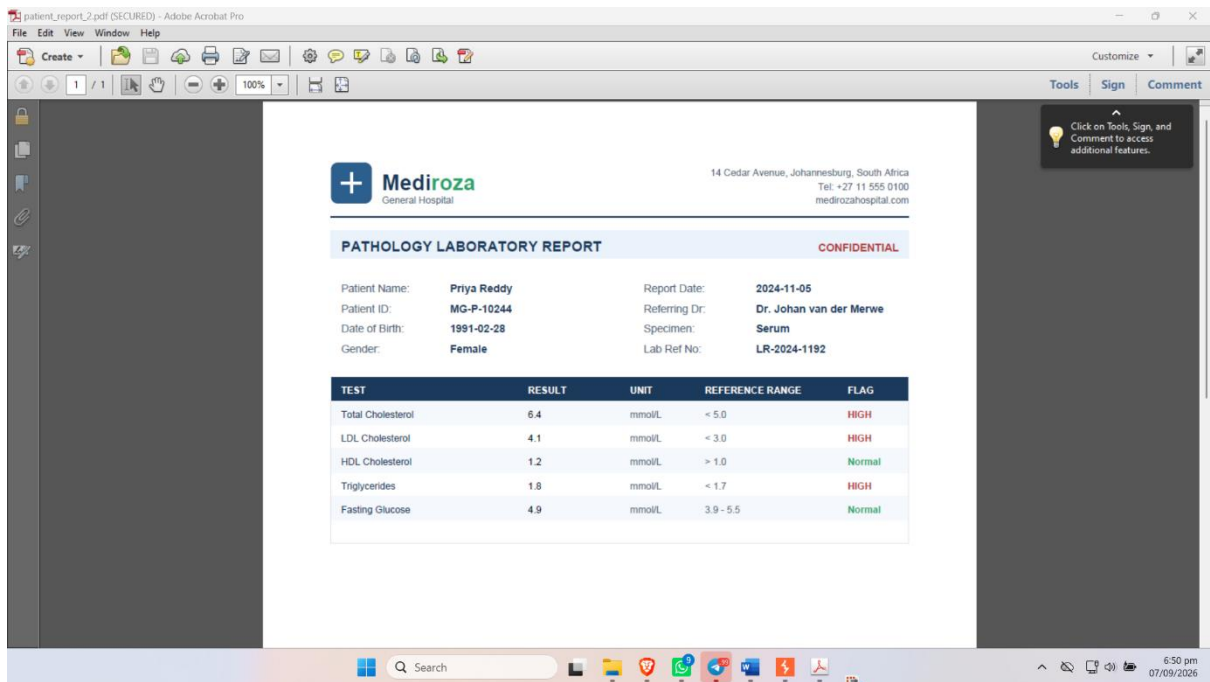


FIGURE 10 PATIENT_REPORT_2 OPENED

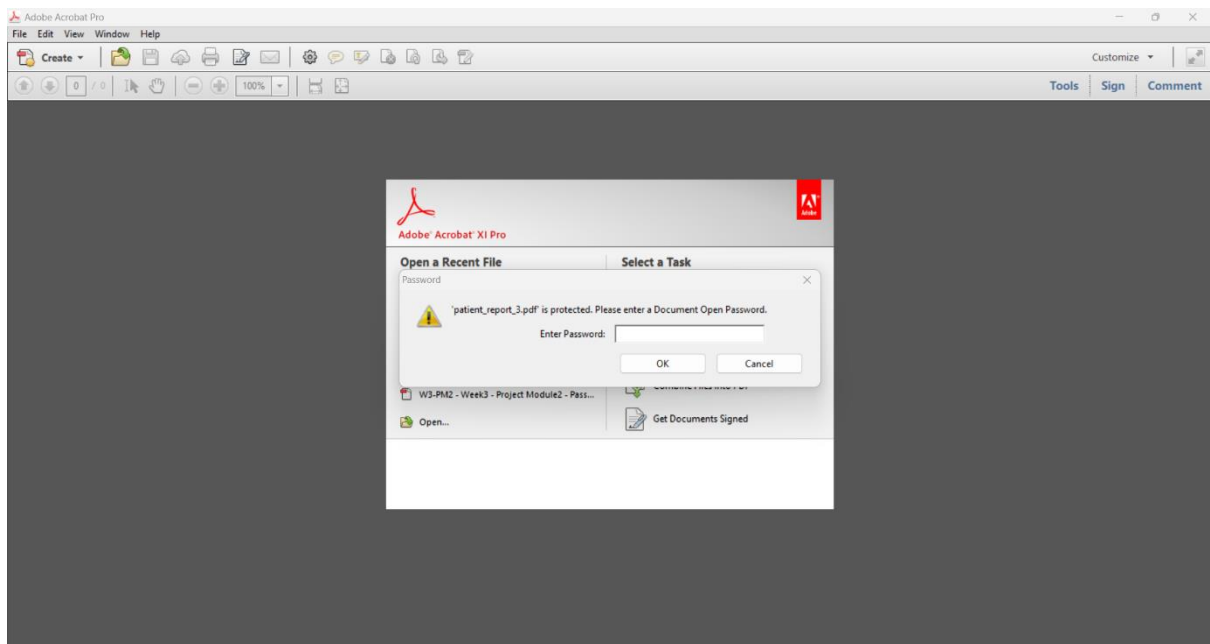


FIGURE 11 PATIENT_REPORT_3 PASSWORD PROTECTED

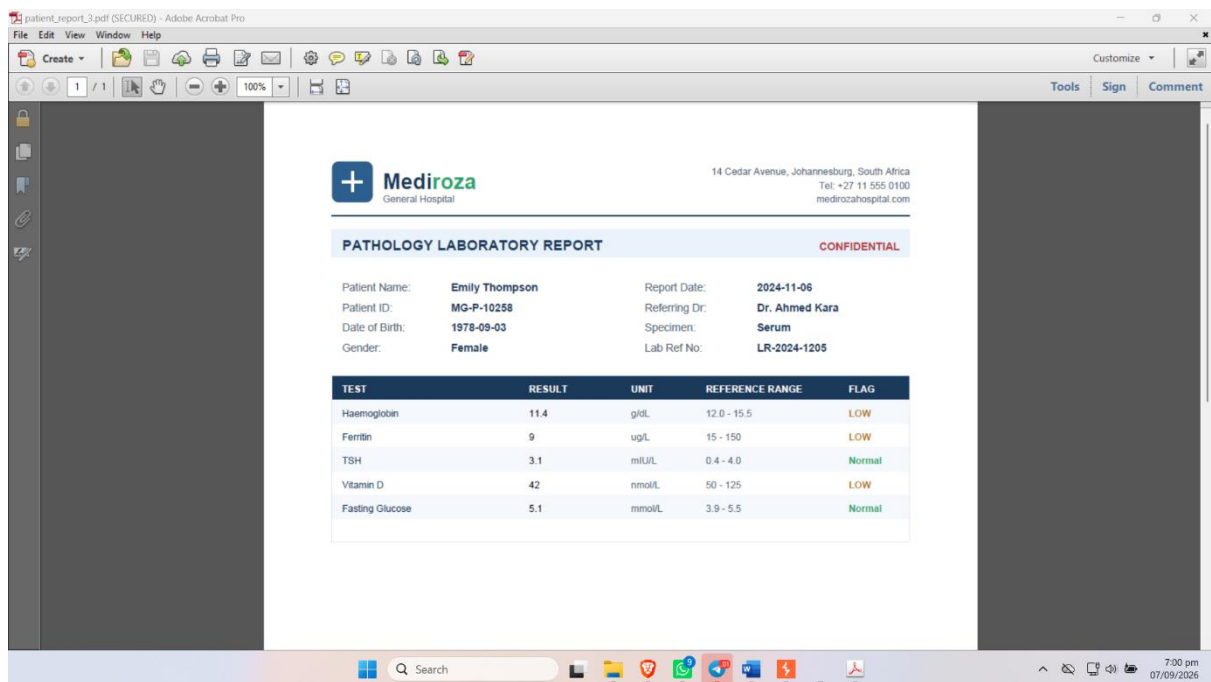


FIGURE 12 PATIENT_REPORT_3 OPENED